Plan de Seguridad y Privacidad de la Información (PSPI)

Alcaldía Municipal de El Rosal – Cundinamarca

Vigencia 2026

TABLA DE CONTENIDO

1. MARCO NORMATIVO **3**
SEGURIDAD DIGITAL Y CIBERSEGURIDAD (ENFOQUE PÚBLICO) 3
PROTECCIÓN DE DATOS PERSONALES Y HABEAS DATA 3
GOBIERNO DIGITAL, TRANSPARENCIA Y GESTIÓN DOCUMENTAL 4
DISPOSICIONES ADMINISTRATIVAS Y PROCESALES 4
NORMAS TÉCNICAS DE REFERENCIA (COMPLEMENTARIAS) 4
2. DIAGNÓSTICO **5**
3. OBJETIVO GENERAL **8**
4. OBJETIVOS ESPECÍFICOS **8**
5. PRINCIPIOS RECTORES **9**
6. EJES ESTRATÉGICOS DEL PLAN **11**
7. PLAN DE ACCIÓN ANUAL **12**
8. SEGUIMIENTO Y EVALUACIÓN **15**
9. PUBLICACIÓN **15**
Públicos Objetivo 15
Responsables **15**
10. ANEXOS **15**
11. APROBACIÓN Y VIGENCIA **15**
12. CONTROL DE ELABORACIÓN DE CAMBIOS **16**

1. MARCO NORMATIVO

El presente Plan de Seguridad y Privacidad de la Información (PSPI) de la Alcaldía Municipal de El Rosal se desarrolla en cumplimiento de las siguientes normas de obligatorio cumplimiento para las entidades públicas en Colombia, estructuradas en los siguientes pilares:

SEGURIDAD DIGITAL Y CIBERSEGURIDAD (ENFOQUE PÚBLICO)

- Ley 1928 de 2018: “Por medio de la cual se aprueba el “Convenio sobre la Ciberdelincuencia”, adoptado el 23 de noviembre de 2001, en Budapest.” Título 1. asistencia mutua en materia de medidas provisionales. Artículo 29. conservación rápida de datos informáticos almacenados.
- Documento CONPES 3701 de 2011: "lineamientos de política para ciberseguridad y ciberdefensa". Documento rector que establece la estrategia nacional y los lineamientos para entidades públicas.
- Documento CONPES 3995 de 2020: "Política Nacional de Seguridad Digital". Documento rector que establece la estrategia nacional y los lineamientos para entidades públicas.
- Documento Maestro de Los Lineamientos del Modelo de Seguridad y Privacidad de la Información (2025, MINTIC) - MSPI, imparte lineamientos a las entidades públicas en materia de implementación y adopción de buenas prácticas, tomando como referencia estándares internacionales, con el objetivo de orientar la gestión e implementación adecuada del ciclo de vida de la seguridad de la información (Planeación, Implementación, Evaluación, Mejora Continua), permitiendo habilitar la implementación de la Política de Gobierno Digital.
- DIRECTIVA PRESIDENCIAL 02 DE 2022: Sobre gestión del riesgo de seguridad digital en la administración pública.

PROTECCIÓN DE DATOS PERSONALES Y HABEAS DATA

- DECRETO 255 de 2022 por el cual se modifica la Ley Estatutaria 1581 de 2012: "Por la cual se dictan disposiciones generales para la protección de datos personales". Aplica a todos los tratamientos de datos realizados por la Alcaldía.
- Decreto 1377 de 2013 y Decreto 886 de 2014: Reglamentan la Ley 1581 de 2012.
- LEY 1266 DE 2008 Parcialmente Reglamentada por el Decreto 1081 de 2015. Ley estudiada por la Corte Constitucional mediante Sentencia C-1011 de 2008: por la cual se dictan las disposiciones generales del hábeas data y se regula el manejo de la información contenida en bases de datos personales, en especial la financiera, crediticia, comercial, de servicios y la proveniente de terceros países y se dictan otras disposiciones.

- Circular Externa 001 del 18 de septiembre de 2025 de la Superintendencia de Industria y Comercio (SIC): Guía para la implementación de programas de protección de datos personales.

GOBIERNO DIGITAL, TRANSPARENCIA Y GESTIÓN DOCUMENTAL

- Ley 2015 de 2020 (Ley de Gobierno Digital): (REEMPLAZA Y CONSOLIDA normativas anteriores). Establece los principios y componentes para la transformación digital del Estado, incluyendo la seguridad digital como pilar fundamental. Deroga expresamente, entre otras, partes de la Ley 962 de 2005 y el Decreto 019 de 2012.
- DECRETO 767 DE 2022 (Mayo 16) “Por el cual se establecen los lineamientos generales de la Política de Gobierno Digital y se subroga el Capítulo 1 del Título 9 de la Parte 2 del Libro 2 del Decreto 1078 de 2015, Decreto Único Reglamentario del Sector de Tecnologías de la Información y las Comunicaciones”
- Ley 1712 de 2014 (Ley de Transparencia): "Por medio de la cual se crea la Ley de Transparencia y del Derecho de Acceso a la Información Pública Nacional". Fundamental para el manejo de información pública.
- Ley 594 de 2000 (Ley General de Archivos): Norma la gestión de documentos físicos y electrónicos.
- Acuerdo 03 de 2015 del Archivo General de la Nación: "Lineamientos generales sobre la gestión de documentos electrónicos de archivo". Es específico y obligatorio para la conservación segura de documentos electrónicos.
- Ley 57 de 1985: Sobre publicidad de actos oficiales.

DISPOSICIONES ADMINISTRATIVAS Y PROCESALES

- Ley 1437 de 2011: Código de Procedimiento Administrativo y de lo Contencioso Administrativo. Contiene principios de actuación administrativa que incluyen la eficiencia y la seguridad de la información.
- Ley Estatutaria 1757 de 2015: Sobre promoción y protección del derecho a la participación democrática.
- Ley Estatutaria 1618 de 2013: Garantiza los derechos de las personas con discapacidad. Relevante para la accesibilidad y el tratamiento de datos de salud en programas sociales.

NORMAS TÉCNICAS DE REFERENCIA (COMPLEMENTARIAS)

- Norma Técnica Colombiana NTC-ISO/IEC 27001: Estándar internacional para Sistemas de Gestión de Seguridad de la Información (SGSI). Es el referente técnico alineado con el EMSD.

- Título 9 del Decreto 1078 de 2015 (Compilado del Sector TIC): Compilación de normas generales del sector. Su aplicación debe leerse a la luz de las leyes más recientes (Ley 1927/2018, Ley 2015/2020).

2. DIAGNÓSTICO

(Estado actual, resultados de auditorías, brechas, riesgos asociados, etc)

La Alcaldía Municipal de El Rosal ha iniciado un proceso formal de gestión de seguridad de la información mediante la elaboración de políticas y planes de acción. Existe conciencia sobre la necesidad de proteger la información y se han identificado responsabilidades básicas. Sin embargo, el enfoque actual es reactivo y fragmentado, careciendo de una estrategia integral alineada con los marcos normativos obligatorios para el sector público colombiano.

Así mismo la alcaldía cuenta con fortalezas fundamentales que incluyen: un marco de gobernanza inicial con Responsable de Seguridad y Comité, políticas documentadas, concienciación básica reflejada en planes de capacitación, inventarios parciales de equipos (82), cuentas de correo, y planes específicos para backups y desastres naturales. Esta base institucional representa un punto de partida sólido para la implementación del sistema de seguridad.

ID	BRECHA IDENTIFICADA	CATEGORÍA	NIVEL DE RIESGO	RIESGOS ASOCIADOS (Impacto Probable)	PRIORIDAD
B-01	Incumplimiento del marco normativo obligatorio: No hay evidencia de implementación del Esquema de Madurez en Seguridad Digital (EMSD - Res. 1732/2021 MinTIC), ni alineación con Ley 1927/2018	Cumplimiento Legal	ALTO	• Sanciones de organismos de control (Procuraduría, Contraloría, MinTIC) • Pérdida de reputación institucional • Exclusión de convocatorias o recursos estatales • Inhabilidad para	CRÍTICA

	(Ciberseguridad) y Decreto 1429/2022.			certificaciones públicas	
B-02	Ausencia de Delegado de Protección de Datos Personales: No se ha designado formalmente esta figura obligatoria según Ley 1581/2012.	Privacidad/ Protección de Datos	ALTO	• Investigaciones, multas y/o sanciones de la Superintendencia de Industria y Comercio (SIC) • Vulneración derechos de los ciudadanos • Daño a la confianza pública	CRÍTICA
B-03	Gestión de riesgos informal: No existe un proceso formal basado en metodología reconocida (Ej: Magerit, ISO 27005).	Gestión de Riesgos	ALTO	• Asignación ineficiente de recursos a controles no críticos • Desconocimiento de la exposición real a nuevas amenazas	ALTA
B-04	Controles técnicos insuficientes: No se evidencia implementación de firewall, gestión centralizada de parches, sistemas de detección (IDS/IPS), cifrado de datos sensibles. Seguridad lógica limitada a contraseñas básicas.	Seguridad Técnica	ALTO	• Alta vulnerabilidad a ransomware, phishing y otros ciberataques • Pérdida o robo masivo de información confidencial • Indisponibilidad prolongada de servicios municipales	ALTA
B-05	Programa de Protección de Datos desactualizado: No se evidencia registro de bases de datos ante SIC, cláusulas	Privacidad/Protección de Datos	ALTO	• Sanciones económicas por la SIC • Litigios por parte de ciudadanos afectados	ALTA

	de tratamiento, procedimientos para derechos de los titulares (consultas, reclamos) ni evaluación de transferencias.			• Incumplimiento de contratos con terceros (cláusulas de confidencialidad)	
B-06	Comité de Seguridad con composición limitada: se debe reasignar constantemente el Responsable de Sistemas/TIC y al Delegado de Protección de Datos. Carece de reglas de operación formal (actas, periodicidad).	Gobernanza	MEDIO-ALTO	• Falta de coordinación entre áreas • Baja efectividad en la gestión de incidentes	MEDIA
B-07	Plan de Backups solo para servidores: No se especifica frecuencia de las pruebas de retención, pruebas de restauración.	Continuidad/Resiliencia	MEDIO-ALTO	• Pérdida definitiva de información crítica en desastre • Incapacidad para restaurar servicios en tiempo requerido • Incumplimiento de normativa de archivo	MEDIA
B-08	Plan de Acción inefectivo: Las actividades son de diagnóstico ("identificar", "valorar") no de tratamiento para acciones críticas. Carece de presupuesto asignado.	Gestión de Proyectos	MEDIO	• No se materializan mejoras en la seguridad • Ciclo de mejora continua estancado • Percepción de que la seguridad es solo un documento	MEDIA

B-09	Falta de capacitación especializada: No hay plan de formación específico en normativa (EMSD, Ley 1927, Ley 1581) para el Comité, RSI y personal clave.	Concienciación/Formación	MEDIO	• Toma de decisiones sin conocimiento normativo • Implementación incorrecta de controles • Cultura de seguridad débil en la organización	MEDIA
B-10	Inventarios incompletos: Solo existe inventario de equipos y correos. Falta inventario crítico de: sistemas de información, bases de datos (especialmente con datos personales), aplicaciones críticas, proveedores de TI.	Gestión de Activos	MEDIO	• Imposibilidad de proteger lo que no se conoce • Brechas de seguridad en sistemas no considerados • Incumplimiento de requisitos del EMSD	MEDIA

3. OBJETIVO GENERAL

Establecer e implementar un Sistema Integral de Gestión de Seguridad y privacidad de la Información que garantice la protección de los datos y activos informáticos de la Alcaldía Municipal de El Rosal, asegurando la confidencialidad, integridad y disponibilidad de la información en todos los procesos institucionales, mediante el fortalecimiento de los servicios prestados a través de las TIC, el cumplimiento del marco normativo colombiano aplicable al sector público, y la gestión proactiva de riesgos que permita salvaguardar tanto la información suministrada por los ciudadanos como la generada por la administración municipal, fomentando así la confianza ciudadana y la continuidad operativa de la entidad.

4. OBJETIVOS ESPECÍFICOS

- Garantizar la seguridad física, lógica y de acceso mediante la implementación de controles técnicos y administrativos que protejan la infraestructura tecnológica, los sistemas de información y los datos institucionales.
- Implementar metodologías y prácticas establecidas por el Ministerio de las TIC y la Función Pública, incluyendo el Esquema de Madurez en Seguridad Digital

(EMSD), para el tratamiento adecuado de la información y la protección de datos personales.

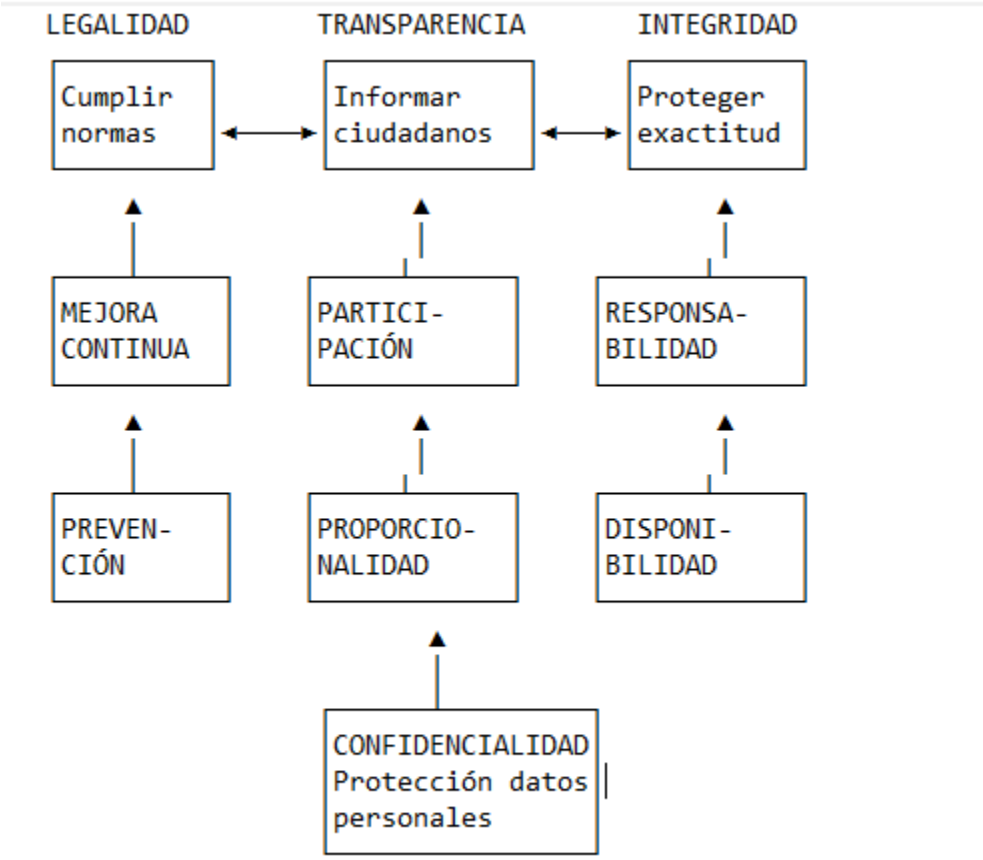
- Establecer un programa de gestión de vulnerabilidades que incluya la actualización periódica de parches de seguridad en sistemas operativos, aplicaciones y software institucional.
- Desarrollar e implementar un plan de continuidad del negocio que proteja la información física y digital contra desastres naturales y otros eventos disruptivos.
- Optimizar la asignación y uso de recursos institucionales para la implementación eficiente del PSPI, priorizando inversiones según el análisis de riesgos y el impacto institucional.
- Fomentar una cultura organizacional de seguridad mediante programas de capacitación, socialización y buenas prácticas dirigidos a funcionarios, contratistas y ciudadanos.

5. PRINCIPIOS RECTORES

El Plan de Seguridad y Privacidad de la Información de la Alcaldía Municipal de El Rosal se fundamenta en los siguientes principios rectores, que guían todas las decisiones, procesos y acciones relacionadas con la gestión de la información:

PRINCIPIO	DEFINICIÓN OPERATIVA
Legalidad	Cumplimiento integral de normas EMSD, Ley 1927, Ley 1581 y demás marco aplicable al sector público en materia de seguridad digital, protección de datos personales, transparencia y gobierno digital.
Transparencia	Acceso público a información no reservada + comunicación clara sobre tratamiento de datos
Integridad	Garantía de exactitud y completitud de la información en todo momento
Confidencialidad	Protección de datos personales y información sensible contra accesos no autorizados

Disponibilidad	Acceso permanente a sistemas e información para servicios municipales
Responsabilidad	Roles definidos + rendición de cuentas por manejo de información
Participación	Involucramiento de toda la organización y ciudadanía en cultura de seguridad
Mejora Continua	Evaluación y actualización permanente de controles y políticas
Proporcionalidad	Medidas de seguridad acordes con criticidad y riesgos reales
Prevención	Enfoque proactivo en gestión de riesgos antes de incidentes



6. EJES ESTRATÉGICOS DEL PLAN

Basado en los marcos normativos obligatorios para el sector público colombiano, específicamente el Esquema de Madurez en Seguridad Digital (EMSD - Resolución 1732 de 2021 del MinTIC), la Ley 1927 de 2018 de Ciberseguridad y la Ley 2015 de 2020 de Gobierno Digital, presentó los ejes estratégicos estandarizados que debe contener el PSPI:

- GOBERNANZA Y LIDERAZGO: Establecer la estructura organizacional, roles, responsabilidades y marco de políticas que direccionen la seguridad digital en la entidad.
- GESTIÓN DE RIESGOS DE SEGURIDAD DIGITAL: Identificar, analizar, evaluar y tratar los riesgos asociados a los activos de información y sistemas digitales.
- PROTECCIÓN Y SEGURIDAD DE ACTIVOS: Implementar controles técnicos, físicos y administrativos para proteger la información y los sistemas.

- GESTIÓN DE INCIDENTES Y CONTINUIDAD: Garantizar la capacidad de respuesta ante incidentes de seguridad y la continuidad de operaciones.
- CUMPLIMIENTO NORMATIVO Y ASEGURAMIENTO: Verificar el cumplimiento de requisitos legales, reglamentarios y contractuales.
- INNOVACIÓN Y MEJORA CONTINUA: Fomentar la adopción de tecnologías seguras y la evolución del sistema de gestión.

7. PLAN DE ACCIÓN ANUAL

(determine las actividades a realizar durante la vigencia 2026 para cada eje estratégico “Nral 6. Ejes estratégicos del plan”)

No.	ACTIVIDAD	META O PRODUCTO	INDICADOR	RESPONSABLE	FECHA INICIO	FECHA FIN
1	Realizar autodiagnóstico EMSD (Esquema de Madurez en Seguridad Digital)	Reporte de diagnóstico con nivel de madurez actual y plan de mejora	• Nivel de madurez inicial identificado • Plan de mejora con al menos 3 acciones prioritarias	TICS - Secretaría de gobierno	Enero	Marzo
2	Implementar Programa de Protección de Datos Personales	Documento PPD y registro bases de datos SIC	• 100% bases de datos con datos personales registradas • Cláusulas de tratamiento actualizadas • Procedimiento para derechos de titulares	TICS - Secretaría de gobierno	Febrero	Marzo
3	Inventariar y clasificar activos de información	Base de datos con inventario completo de	• 100% de sistemas de información inventariados	TICS - Secretaría de gobierno	Marzo	Septiembre

No.	ACTIVIDAD	META O PRODUCTO	INDICADOR	RESPONSABLE	FECHA INICIO	FECHA FIN
		sistemas y datos	• 3 categorías de clasificación definidas (Pública, Reservada, Confidencial)			
4	Realizar evaluación formal de riesgos con Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información	Matriz de riesgos priorizada con valoración cuantitativa	Matriz con mínimo 10 riesgos identificados • Top 3 riesgos críticos con tratamiento definido • Valoración de impacto y probabilidad	TICS - Secretaría de gobierno Calidad	Mayo	Junio
5	Elaborar Plan de Tratamiento de Riesgos 2026-2027	Documento con acciones específicas por riesgo crítico	• 100% de riesgos críticos con tratamiento asignado • Plan con acciones priorizadas • Presupuesto estimado por acción	TICS - Secretaría de gobierno	Enero	Enero
6	Implementar solución de firewall perimetral	Firewall instalado y configurado con políticas básicas	• 1 firewall físico/cloud implementado • Políticas de acceso definidas • Red segmentada en VLANs	TICS - Secretaría de gobierno	Junio	Diciembre

No.	ACTIVIDAD	META O PRODUCTO	INDICADOR	RESPONSABLE	FECHA INICIO	FECHA FIN
7	Establecer gestión centralizada de parches de seguridad	Sistema de parcheo automatizado en 80% de equipos	• Inventario de software actualizado • Ventana de mantenimiento mensual establecida	TICS - Secretaría de gobierno	Mayo	Diciembre
8	Implementar sistema de backups 3-2-1	Copias automatizadas diarias + verificación semanal	• 3 copias de datos críticos • 2 medios diferentes (disco + cloud) • 1 copia externa • Pruebas de restauración semestrales	TICS - Secretaría de gobierno	Enero	Diciembre
9	Implementar programa de capacitación en seguridad y phishing	capacitaciones realizadas	• 80% de funcionarios capacitados • Material didáctico desarrollado • Evaluación de aprendizaje aplicada	TICS - Secretaría de gobierno	Marzo	Septiembre
10	Realizar auditoría interna de seguridad	Informe de auditoría con hallazgos y plan de acción	controles evaluados: • Reporte con nivel de cumplimiento • Plan de acción	TICS - Secretaría de gobierno Calidad		

8. SEGUIMIENTO Y EVALUACIÓN

El seguimiento al cumplimiento de las actividades del Plan de Seguridad y Privacidad de la Información, se realizará de forma continua por parte de los responsables de las actividades. Además, se llevará a cabo el monitoreo:

Corte	Responsable	Producto
Enero- Junio	Control Interno	Informe Seguimiento
Julio-Diciembre	Control Interno	Informe Evaluación

9. PUBLICACIÓN

https://www.elrosal-cundinamarca.gov.co/ – Sección transparencia y acceso a la información.

Públicos Objetivo

- Funcionarios y contratistas de la entidad.
- Directivos y líderes de proceso.
- Ciudadanía en general.
- Entidades y actores externos.

Responsables

- Oficina de Tecnologías de la Información y las Comunicaciones – TIC / Prensa y Comunicaciones.
- Líderes de proceso de la entidad.

10. ANEXOS

articles-418986_recurso_1.pdf

11. APROBACIÓN Y VIGENCIA

El presente plan rige a partir de su adopción mediante acto administrativo, será de obligatorio cumplimiento y se actualizará cuando se presenten cambios normativos, organizacionales o estratégicos, o como resultado de evaluaciones institucionales.

12. CONTROL DE ELABORACIÓN DE CAMBIOS

	Nombre	Cargo	Fecha
Elaboró	Luis Sandoval Fuentes	Contratista TIC's - SGG	19/01/2026
Revisó	Bibiana Gonzalez Rojas	Secretaria general y de gobierno	26/01/2026
Aprobó	Bibiana Gonzalez Rojas	Secretaria general y de gobierno	26/01/2026

Versión	Fecha de Cambio	Resumen de Cambios
1	26/01/2026	